2026

POLITIQUE DE SÉCURITÉ CLOUD

DOCUMENT DE REFERENCE

SOCIÉTÉ TABAGO

Version 1.0 | Classification : CONFIDENTIEL

03/03/2026

Usage réservé aux équipes techniques et parties

FICHE D'IDENTITÉ DU DOCUMENT

Champ	Valeur
Organisation	TALBAGO
Titre du document	Politique de Sécurité Cloud (PSC)
Reference	TALBAGO-PSC-2025-v1.0
Version	1.0
Date de création	Mars 2025
Prochaine révision	Mars 2026 (révision annuelle recommandée)
Propriétaire	Responsable de la Sécurité des SI (RSSI)
Classification	CONFIDENTIEL — Usage interne
Statut	Approuvé
Périmètre	Tous environnements Cloud TALBAGO (IaaS/PaaS/SaaS)

Tableau d'approbation

Rôle	Nom	Fonction	Date	Visa
Auteur	GOUNOU Boubacar	Consultant sécurité	Mars 2025	
Reviseur		DSI	Mars 2025	
Approbateur		Direction Générale	Mars 2025	

Historique des révisions

Version	Date	Auteur	Nature des modifications
1.0	Mars 2025	RSSI TALBAGO	Création initiale du document

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

TABLE DES MATIÈRES

1. PREAMBULE ET CONTEXTE TALBAGO 4
2. OBJECTIFS ET PERIMETRE DE LA POLITIQUE 4
2.1 Objectifs 4
2.2 Périmètre d'application 4
2.3 Exclusions 4
GOUVERNANCE DE LA SECURITE CLOUD 6
3.1 Rôles et responsabilités 6
3.2 Comite Cloud Security 6
3.3 Gestion des fournisseurs Cloud 6
4. PRINCIPES GENERAUX DE SECURITE CLOUD 7
4.1 Modèle de responsabilité partagée 7
4.2 Principes directeurs de sécurité 7
4.3 Approche Zéro Trust 8
5. CLASSIFICATION ET PROTECTION DES DONNÉES 9
5.1 Niveaux de classification 9
5.2 Règles de traitement par niveau 9
5.3 Résidence et souveraineté des données 9
6. GESTION DES IDENTITÉS ET DES ACCÈS (IAM) 10
6.1 Principes de contrôle d'accès 10
6.2 Authentification multi-facteurs (MFA) 10
6.3 Gestion des comptes a privilèges (PAM) 10
7. SÉCURITÉ DES DONNÉES 11
7.1 Chiffrement 11
7.2 Sauvegarde et Plan de Reprise d'Activité (PRA) 11
7.3 Gestion du cycle de vie des données 11
8. SÉCURITÉ RÉSEAU ET INFRASTRUCTURE 12
8.1 Architecture et segmentation réseau 12
8.2 Sécurité des endpoints 12
8.3 Supervision, journalisation et détection des menaces 12
9. SÉCURITÉ APPLICATIVE ET DEVSECOPS 13
9.1 Security by Design 13
9.2 Intégration sécurité dans les pipelines CI/CD 13
9.3 Gestion des vulnérabilités 13
10. GESTION DES INCIDENTS DE SÉCURITÉ CLOUD 14
10.1 Classification des incidents 14
10.2 Procédure de réponse aux incidents 14
10.3 Obligations de notification RGPD 14
11. GESTION DES RISQUES CLOUD 15
11.1 Analyse et cartographie des risques 15
11.2 Traitement et suivi des risques 15
12. CONFORMITÉ, AUDITS ET PILOTAGE 16

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

12.1 Référentiels et règlementations applicables 16
12.2 Audits et contrôles périodiques 16
12.3 Indicateurs de pilotage (KPI Sécurité Cloud) 17
13. FORMATION ET SENSIBILISATION 18
14. RÉVISION ET MISE A JOUR DE LA POLITIQUE 19
ANNEXES 20
Annexe A — Inventaire des services Cloud TALBAGO 20
Annexe B — Matrice RACI 20
Annexe C — Contacts d'urgence sécurité Cloud 21
Annexe D — Glossaire 21

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

1. PREAMBULE ET CONTEXTE TALBAGO

TALBAGO s'appuie sur des environnements Cloud pour héberger ses applications métier, stocker ses données et soutenir ses opérations. Cette transformation numérique génère des opportunités significatives en termes d'agilité, de sociabilité et de performance, mais elle expose également l'organisation a de nouveaux risques de sécurité qui doivent être maitrisés.
La présente Politique de Sécurité Cloud (PSC) constitue le document de référence définissant le cadre opérationnel, les exigences et les bonnes pratiques applicables à l'ensemble des environnements Cloud de TALBAGO. Elle s'inscrit dans la continuité de la stratégie de sécurité définie par la Direction et vise à garantir la protection des actifs, des données et des services dans le Cloud.

INFO	Cette politique est opposable à tous les acteurs internes et externes intervenant sur les environnements Cloud de TALBAGO. Toute dérogation doit être formellement approuvée par le RSSI.

2. OBJECTIFS ET PERIMETRE DE LA POLITIQUE

2.1 Objectifs

La Politique de Sécurité Cloud de TALBAGO poursuit les objectifs suivants :

- **Formaliser un cadre de référence** définissant les principes, règles et bonnes pratiques de sécurité applicables aux environnements Cloud.
- **Protéger les actifs et les données** de TALBAGO contre les menaces internes et externes liées a l'usage du Cloud.
- **Garantir la continuité d'activité** et la disponibilité des services Cloud critiques.
- **Assurer la conformité règlementaire** aux exigences applicables (RGPD, NIS2, et toute règlementation sectorielle pertinente).
- **Définir les responsabilités** de chaque partie prenante dans la gestion de la sécurité Cloud.
- **Sécuriser les projets Cloud actuels et futurs** dès leur conception (Security by Design).
- **Piloter la sécurité Cloud** via des indicateurs, des audits et une amélioration continue.

2.2 Périmètre d'application

La présente politique s'applique a :

- L'ensemble des collaborateurs TALBAGO utilisant ou administrant des services Cloud.
- Les prestataires, sous-traitants et partenaires intervenant sur les environnements Cloud de TALBAGO.
- Tous les modèles de service Cloud utilises : Infrastructure as a Service (IaaS), Platform as a Service (PaaS), Software as a Service (SaaS).
- Tous les modèles de déploiement : Cloud public, Cloud prive, Cloud hybride ou multi-Cloud.
- L'ensemble des données traitées, stockées ou transmises via les environnements Cloud.
- Tous les équipements et terminaux utilises pour accéder aux services Cloud de TALBAGO.

2.3 Exclusions

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

Sont exclus du périmètre de cette politique : les environnements de développement et de test totalement isoles ne traitant aucune donnée de production, ainsi que les usages personnels des collaborateurs non connectes aux systèmes d'information de TALBAGO. Toute exception doit être documentée et approuvée par le RSSI.

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

GOUVERNANCE DE LA SECURITE CLOUD

3.1 Rôles et responsabilités

Rôle	Responsable	Responsabilités principales
Direction Générale	DG	Approuve la politique, alloue les ressources, responsabilité ultime de la sécurité
RSSI	RSSI TALBAGO	Définit et pilote la stratégie sécurité Cloud, valide les dérogations, supervise la conformité
DSI	DSI	Valide les choix d'architecture Cloud, intègre la sécurité dans les projets
Administrateurs Cloud	Équipe IT Cloud	Configurent et maintiennent les environnements Cloud selon les exigences de la PSC
DPO	DPO TALBAGO	Assure la conformité RGPD des traitements Cloud, gère les violations de données
Chefs de projet	Project Managers	Intègrent les exigences de sécurité dès la conception, alertent le RSSI
Utilisateurs	Tous collaborateurs	Respectent la présente politique, signalent tout incident ou comportement anormal
Fournisseurs Cloud	Prestataires	Respectent les exigences contractuelles, fournissent rapports de conformité

3.2 Comite Cloud Security

Un Comité Cloud Security est institué au sein de TALBAGO. Il se réunit trimestriellement et regroupe le RSSI, le DSI, le DPO, les responsables des projets Cloud et les référents métiers. Ses missions incluent :

- L'examen des indicateurs de sécurité Cloud (tableaux de bord, KPI).
- La validation des exceptions et des dérogations à la présente politique.
- La revue des incidents survenus et des plans de remédiation.
- L'approbation des évolutions d'architecture Cloud et des nouveaux fournisseurs.
- La mise à jour annuelle de la présente politique.

3.3 Gestion des fournisseurs Cloud

Tout recours à un fournisseur Cloud fait l'objet d'une évaluation sécurité préalable conduite par le RSSI. Les critères d'évaluation incluent : la localisation des données, les certifications de sécurité (ISO 27001, SOC 2, HDS...), les capacités de réversibilité, les modalités de gestion des incidents et les clauses contractuelles (SLA, DPA, accords de confidentialité).

ATTENTION	Aucun service Cloud ne peut être mis en production sans validation préalable du RSSI et signature d'un contrat de traitement de données conforme aux exigences RGPD de TALBAGO.

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

4. PRINCIPES GENERAUX DE SECURITE CLOUD

4.1 Modèle de responsabilité partagée

Le Cloud repose sur un modèle de responsabilité partagée entre TALBAGO et ses fournisseurs. La répartition des responsabilités varie selon le modèle de service :

Domaine de responsabilité	IaaS	PaaS	SaaS
Données et contenu	TALBAGO	TALBAGO	TALBAGO
Identités et accès (IAM)	TALBAGO	TALBAGO	Partage
Applications	TALBAGO	Partage	Fournisseur
Système d'exploitation	TALBAGO	Fournisseur	Fournisseur
Réseau virtuel	Partage	Fournisseur	Fournisseur
Infrastructure physique	Fournisseur	Fournisseur	Fournisseur

INFO	Quelle que soit la responsabilité technique du fournisseur, TALBAGO reste responsable de la protection de ses données et de la conformité réglementaire de leurs traitements.

4.2 Principes directeurs de sécurité

Principe	Description
Moindre privilège	Chaque utilisateur, système ou service dispose uniquement des droits strictement nécessaires a sa fonction.
Défense en profondeur	Mise en œuvre de multiples couches de sécurité complémentaires et indépendantes.
Security by Design	La sécurité est intégrée dès la conception de tout projet Cloud, non ajoutée a posteriori.
Chiffrement par défaut	Toutes les données sensibles sont chiffrées au repos et en transit, sans exception.
Traçabilité complète	Toutes les actions sur les environnements Cloud sont journalisées, conservées et auditables.
Continuité et résilience	Les services critiques disposent de plans de reprise garantissant la continuité des opérations.
Amélioration continue	La sécurité Cloud fait l'objet d'évaluations régulières et d'un plan d'amélioration formalise.
Conformité par défaut	Les configurations Cloud sont conformes aux référentiels applicables dès le déploiement initial.

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

4.3 Approche Zéro Trust

TALBAGO adopte les principes du modèle Zéro Trust : aucun utilisateur, équipement ou réseau n'est considéré comme fiable par défaut, qu'il soit interne ou externe. Cette approche repose sur trois piliers :

- **Vérifier explicitement :** chaque accès est authentifié, autorisé et chiffré, quels que soient l'utilisateur et le contexte.
- **Accorder le moindre privilège :** les accès sont limités au strict nécessaire, avec élévation de privilèges temporaire et tracée.
- **Supposer la compromission :** l'architecture est conçue pour détecter, contenir et récupérer rapidement en cas d'intrusion.

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

5. CLASSIFICATION ET PROTECTION DES DONNÉES

5.1 Niveaux de classification

Niv.	Label	Description	Exemples	Cloud autorisé
N4	SECRET	Confidentialité absolue. Impact critique si divulgué.	Secrets commerciaux, données biométriques, mots de passe maitres	Interdit sans HSM + validation RSSI
N3	CONFIDENTIEL	Usage interne restreint. Impact fort si divulgué.	Données clients, RH, financières, contrats	Cloud souverain UE, chiffrement BYOK obligatoire
N2	INTERNE	Usage interne général. Impact modéré si divulgué.	Procédures, emails internes, projets en cours	Cloud approuvé, MFA obligatoire
N1	PUBLIC	Diffusion libre sans restriction.	Communiqués de presse, documentation publique	Tous services Cloud approuvés

5.2 Règles de traitement par niveau

- Toute donnée stockée dans le Cloud doit être classifiée avant son hébergement.
- Le propriétaire de la donnée est responsable de son étiquetage et des règles d'accès associées.
- Le niveau de protection des contenants doit correspondre au niveau le plus élevé des données hébergées.
- Le croisement de données de niveaux différents dans un même environnement non cloisonne est interdit.

5.3 Résidence et souveraineté des données

RÈGLE	Les données de niveau CONFIDENTIEL et SECRET de TALBAGO doivent impérativement être hébergées dans l'Union Européenne. Tout transfert vers un pays tiers nécessite une autorisation préalable du RSSI et du DPO, et doit s'appuyer sur un mécanisme de transfert conforme au RGPD (clauses contractuelles types, décision d'adéquation, etc.).

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

6. GESTION DES IDENTITÉS ET DES ACCÈS (IAM)

6.1 Principes de contrôle d'accès

- **Moindre privilège :** attribution des droits minimaux nécessaires à la fonction exercée.
- **Séparation des tâches :** les rôles d'administrateur, d'auditeur et d'utilisateur sont strictement distincts.
- **Approvisionnement formalisé :** toute création, modification ou suppression de compte suit un processus approuvé par le RSSI.
- **Révocation immédiate :** les accès sont supprimés dans les 24 heures suivant le départ ou le changement de fonction.
- **Revue périodique :** les droits d'accès sont revus trimestriellement. Les droits non justifiés sont révoqués.
- **Interdiction des comptes partages :** chaque utilisateur dispose d'un compte nominatif unique.

6.2 Authentification multi-facteurs (MFA)

Type de compte	MFA	Méthode requise	Commentaire
Comptes administrateurs Cloud	**Obligatoire**	FIDO2 / Clé matérielle	Tolérance zéro — pas d'exception
Utilisateurs standard	**Obligatoire**	Application TOTP / Passkey	SMS déconseillé (SIM swapping)
Accès depuis réseau non fiable	**Obligatoire**	MFA + VPN / ZTNA	Double vérification systématique
Comptes de service / API	Clé API	Rotation tous les 90 jours	Stockage dans un vault (ex. HashiCorp Vault)

6.3 Gestion des comptes à privilèges (PAM)

- Les comptes à privilèges font l'objet d'une gestion renforcée via une solution PAM dédiée.
- L'élévation de privilèges est temporaire, tracée et soumise à approbation pour les opérations sensibles.
- Les sessions d'administration sont enregistrées et conservées pendant 12 mois minimum.
- Les accès aux consoles Cloud sont limités aux IP des postes d'administration approuvés
- Les comptes de service n'ont aucun droit d'accès interactif et sont soumis à rotation automatique.

CRITIQUE	Il est formellement interdit de stocker des secrets (mots de passe, clés API, certificats) en clair dans le code source, les fichiers de configuration, les dépôts Git ou les variables d'environnement non protégés.

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

7. SÉCURITÉ DES DONNÉES

7.1 Chiffrement

Contexte	Standard minimum	Gestion des clés
Données en transit	TLS 1.2 min. (TLS 1.3 recommandé)	Certificats gérés, renouvellement automatique, HSTS active
Données au repos — N3/N4	AES-256	BYOK — clés gérées par TALBAGO via KMS / HSM
Données au repos — N1/N2	AES-256	Clés gérées par le fournisseur Cloud (CMK)
Sauvegardes	AES-256	Clés distinctes de la production, rotation annuelle
Secrets applicatifs	AES-256 + enveloppe	Stockage exclusif dans un coffre-fort (Vault), jamais en clair

7.2 Sauvegarde et Plan de Reprise d'Activité (PRA)

Paramètre	Exigence
Fréquence	Quotidienne pour données de production (N2/N3), hebdomadaire pour N1
Rétention	30 jours pour sauvegardes courantes, 1 an pour archives règlementaires
Redondance	Minimum 2 copies dans des zones de disponibilité ou régions distinctes
Chiffrement	Obligatoire avec clés distinctes de celles de la production
Tests de restauration	Trimestriels, documenté avec rapport transmis au RSSI
RTO (Recovery Time Obj.)	< 4 heures pour services critiques, < 24h pour services standards
RPO (Recovery Point Obj.)	< 1 heure pour services critiques, < 24h pour services standards

7.3 Gestion du cycle de vie des données

- Les données sont supprimées de manière sécurisée (effacement cryptographique ou destruction certifiée) a l'expiration de leur durée de conservation.
- En fin de contrat avec un fournisseur Cloud, TALBAGO exige la restitution de ses données et leur suppression certifiée dans un délai de 30 jours.
- Les politiques de rétention sont définies en accord avec le DPO et conformes aux obligations légales applicables.

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

8. SÉCURITÉ RÉSEAU ET INFRASTRUCTURE

8.1 Architecture et segmentation réseau

- **Isolation des environnements :** Production, Staging, Développement et Test sont strictement séparés (VPC / VNet distincts).
- **Segmentation micro-services :** les flux interservices sont limités aux communications nécessaires, documentées et contrôlées.
- **Accès distant sécurisé :** tout accès aux ressources Cloud depuis l'extérieur passe par VPN / Zero Trust Network Access.
- **Pas d'exposition directe :** aucune ressource sensible n'est exposée sur Internet sans protection WAF et contrôle d'accès.
- **Liste blanche :** les consoles d'administration Cloud sont accessibles uniquement depuis des IP autorisées et documentées.
- **Désactivation des services inutiles :** tout service, port ou protocole non utilise est désactivé par défaut.

8.2 Sécurité des endpoints

- Les postes utilisent pour administrer les environnements Cloud sont des postes dédiés, durcis et sous contrôle IT.
- Un EDR (Endpoint Detection and Response) est déployé sur tous les postes accédant aux ressources Cloud.
- Les terminaux mobiles accédant aux services Cloud sont enrôlés dans une solution MDM (Mobile Device Management).
- Les accès depuis des appareils personnels (BYOD) sont interdits pour les opérations d'administration Cloud.

8.3 Supervision, journalisation et détection des menaces

Capacité	Exigence	Rétention
Journaux d'accès	Activés sur tous les services Cloud (audit logs, Access logs, event logs)	12 mois
SIEM	Centralisation des logs Cloud avec règles d'alerte sur évènements suspects	12 mois
CSPM	Cloud Security Posture Management : contrôle continu de la conformité des configurations	6 mois
Alertes temps réels	Connexions depuis géographies inhabituelles, escalades de privilèges, exports massifs de données	—
Analyse de vulnérabilités	Scans mensuels des ressources exposées. Correction sous 30 jours (critiques : 72h)	6 mois
Tests d'intrusion	Annuels, réalisés par un prestataire qualifié. Rapport + plan de remédiation obligatoire	5 ans

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

9. SÉCURITÉ APPLICATIVE ET DEVSECOPS

9.1 Security by Design

La sécurité est intégrée à chaque étape du cycle de développement logiciel (SDLC) et des projets Cloud. Dès la phase de conception, une analyse des risques est conduite et les exigences de sécurité sont formalisées.

- Évaluation des risques et Privacy Impact Assessment (PIA) en phase de conception.
- Modélisation des menaces (Threat Modeling) pour les architectures Cloud critiques.
- Revue de sécurité obligatoire avant mise en production de tout nouveau service Cloud.
- Architecture Cloud documentée et validée par le RSSI avant déploiement.

9.2 Intégration sécurité dans les pipelines CI/CD

- **SAST (Static Analysis) :** analyse du code source à chaque commit pour détecter les vulnérabilités connues.
- **SCA (Software Composition Analysis) :** contrôlé des dépendances et des bibliothèques tierces utilisées.
- **Scan d'images conteneurs :** les images Docker/OCI sont analysées avant déploiement dans les registres.
- **IaC Security :** les scripts d'infrastructure (Terraform, CloudFormation) sont analysés par des outils dédiés.
- **Filtrage de** sécurité : une vulnérabilité critique bloque automatiquement le pipeline de déploiement.

9.3 Gestion des vulnérabilités

Sévérité	Délai de correction	Responsable
CRITIQUE (CVSS 9-10)	**72 heures**	RSSI + Admin Cloud — escalade Direction
HAUTE (CVSS 7-8.9)	7 jours	Admin Cloud — rapport RSSI
MOYENNE (CVSS 4-6.9)	30 jours	Admin Cloud
FAIBLE (CVSS < 4)	90 jours	Admin Cloud — prochain cycle de maintenance

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

10. GESTION DES INCIDENTS DE SÉCURITÉ CLOUD

10.1 Classification des incidents

Priorité	Critères	Délai de prise en charge	Exemples
P1 — CRITIQUE	Impact majeur sur la continuité ou la confidentialité des données	**< 1 heure**	Ransomware, fuite de données massive, accès non autorisé à des données confidentielles
P2 — ÉLEVÉE	Impact significatif sur un service ou un périmètre limite	< 4 heures	Compte administrateur compromis, exfiltration de données N2, DDoS
P3 — MOYENNE	Impact limite, service partiellement affecte	< 24 heures	Tentative d'intrusion bloquée, misconfiguration détectée
P4 — FAIBLE	Impact mineur ou potentiel non confirmé	< 72 heures	Anomalie de configuration mineure, alerte non confirmée

10.2 Procédure de réponse aux incidents

Étape	Description
1. DÉTECTION	Identification via SIEM, alerte automatique, signalement utilisateur ou notification fournisseur.
2. QUALIFICATION	Évaluation de la priorité (P1-P4), périmètre impacte, données concernées, responsable désigné.
3. CONFINEMENT	Isolation immédiate des ressources compromises, révocation des accès suspects, préservation des preuves.
4. INVESTIGATION	Analyse forensique des journaux, identification de la cause racine, évaluation de l'étendue réelle.
5. REMÉDIATION	Correction des failles exploitées, restauration depuis sauvegardes saines, durcissement.
6. NOTIFICATION	Notification CNIL dans les 72h si données personnelles concernées (RGPD Art. 33). Communication aux parties prenantes.
7. CLÔTURE	Rapport post-incident (post-mortem), retour d'expérience, mise à jour des procédures et règles de détection.

10.3 Obligations de notification RGPD

RÈGLE	En cas de violation de données à caractère personnel impliquant des environnements Cloud, TALBAGO doit notifier la CNIL dans les 72 heures suivant la prise de connaissance de l'incident (Art. 33 RGPD). Si la violation est susceptible d'engendrer un risque élevé pour les droits et libertés des personnes concernées, celles-ci doivent également être informées dans les meilleurs délais (Art. 34 RGPD). Le DPO coordonne ces obligations.

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

11. GESTION DES RISQUES CLOUD

11.1 Analyse et cartographie des risques

Une analyse des risques spécifique aux environnements Cloud est conduite annuellement par le RSSI, en s'appuyant sur les référentiels EBIOS Risk Manager et/ou ISO 27005. Elle couvre les dimensions techniques, organisationnelles, juridiques et contractuelles.

Catégorie de risque	Exemples de menaces	Mesures de traitement
Violation de données	Exfiltration, accès non autorisé, ransomware	Chiffrement, IAM strict, détection comportementale
Perte de disponibilité	Panne fournisseur, DDoS, erreur de configuration	Multi-AZ, PRA teste, SLA contractuels
Verrouillage fournisseur	Dépendance technique, fin de service	Architecture portable, clauses de réversibilité
Non-conformité réglementaire	Transfert hors UE, non-respect RGPD	DPA, résidence des données, audits de conformité
Erreur de configuration	Bucket public, ports ouverts, droits excessifs	CSPM, revue des configurations, IaC sécurisé
Compromission supply chain	Librairie compromise, prestataire malveillant	SCA, évaluation fournisseurs, zéro trust

11.2 Traitement et suivi des risques

- Chaque risque identifié fait l'objet d'une décision de traitement : réduction, transfert (assurance cyber), acceptation formelle ou évitement.
- Un registre des risques Cloud est maintenu par le RSSI et mis à jour a minima trimestriellement.
- Les risques résiduels acceptés font l'objet d'une validation formelle par la Direction.
- Le plan de traitement est présenté au Comité Cloud Security à chaque réunion trimestrielle.

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

12. CONFORMITÉ, AUDITS ET PILOTAGE

12.1 Référentiels et règlementations applicables

Référentiel	Domaine	Statut TALBAGO	Responsable
RGPD / GDPR	Protection des données personnelles	Applicable	DPO
NIS 2	Sécurité des réseaux et SI critiques	À évaluer	RSSI
ISO 27001	Système de management de la sécurité de l'information	Cible	RSSI
ISO 27017	Sécurité spécifique Cloud	Recommandé	RSSI
SecNumCloud	Qualification Cloud souverain (ANSSI)	Fournisseurs	DSI
SOC 2 Type II	Contrôles sécurité fournisseurs Cloud	Exigés fournisseurs	RSSI
DORA	Résilience opérationnelle numérique	À évaluer	DSI

12.2 Audits et contrôles périodiques

Type d'audit	Fréquence	Responsable	Livrables
Revue des droits d'accès	Trimestrielle	RSSI + RH	Rapport de droits — actions correctives
Revue des configurations CSPM	Mensuelle	Admin Cloud	Tableau de bord conformité — tickets de correction
Audit interne sécurité Cloud	Semestrielle	RSSI	Rapport d'audit — plan d'action
Test de restauration PRA	Trimestrielle	Admin Cloud	PV de test — rapport RTO/RPO
Test d'intrusion (Pentest)	Annuelle	Prestataire qualifié	Rapport de pentest — plan de remédiation
Audit fournisseurs Cloud	Annuelle	RSSI + Achats	Rapport de conformité fournisseur

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

12.3 Indicateurs de pilotage (KPI Sécurité Cloud)

Indicateur	Description	Cible	Fréquence
Taux de conformité MFA	% de comptes avec MFA active	> 99%	Mensuelle
Délai moyen de remédiation	Vulnérabilités critiques/hautes corrigées	< 7 jours	Mensuelle
Conformité configurations	% ressources configurées conformément aux standards CSPM	> 95%	Mensuelle
Taux de sauvegarde testée	% sauvegardes testées avec succès	100%	Trimestrielle
Incidents P1/P2 résolus dans les délais	% incidents critiques traites dans les SLA	100%	Mensuelle
Score de maturité sécurité Cloud	Évaluation globale du niveau de sécurité Cloud	Progression	Annuelle

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

13. FORMATION ET SENSIBILISATION

Public cible	Formation	Fréquence	Format
Tous collaborateurs	Sensibilisation aux risques Cloud, phishing, bonnes pratiques	Annuelle	E-learning
Équipes IT / Dev	Sécurité Cloud architecture, DevSecOps, OWASP Top 10	Annuelle	Présentiel
Administrateurs Cloud	Certification Cloud Security (AWS/Azure/GCP Security Specialty)	Prise de poste	Certification
Direction et managers	Gouvernance, obligations légales, gestion de crise	Annuelle	Atelier
Nouveaux arrivants	Intégration sécurité Cloud — principes de base	J+30	Onboardin

Des simulations de hameçonnage sont organisées semestriellement. Les résultats alimentent le plan de sensibilisation et sont présentes au Comité Cloud Security.

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

14. RÉVISION ET MISE A JOUR DE LA POLITIQUE

La présente Politique de Sécurité Cloud est révisée annuellement par le RSSI et soumise à l'approbation de la Direction. Elle peut faire l'objet d'une révision exceptionnelle lors de la survenance des évènements suivants :

- Incident de sécurité majeur (P1 ou P2) impliquant un environnement Cloud.
- Évolution significative de la réglementation applicable (RGPD, NIS2, DORA…).
- Changement d'architecture Cloud ou adoption d'un nouveau fournisseur stratégique.
- Résultat d'audit révélant des non-conformités majeures.
- Évolution du contexte de menace cybersécurité touchant les environnements Cloud.

INFO	Toute demande d'évolution de la présente politique doit être adressée au RSSI avec une justification écrite. Les modifications sont validées par le Comité Cloud Security avant publication.

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

ANNEXES

Annexe A — Inventaire des services Cloud TALBAGO

Service	Fournisseur	Type	Usage / Données	Classification	Responsable

Annexe B — Matrice RACI

R = Responsable de l'exécution | A = Approbateur | C = Consulté | I = Informé

Activité	RSSI	DSI	Admin Cloud	DPO	Dev	Direction
Définir la politique sécurité	R/A	C	C	C	I	A
Gestion des accès IAM	A	C	R	I	C	I
Réponse aux incidents	A	C	R	C	C	I
Notification CNIL	C	I	I	R/A	I	I
Audits de sécurité	R/A	I	C	C	I	I
Choix fournisseur Cloud	A	R	C	C	C	A

Annexe C — Contacts d'urgence sécurité Cloud

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

Rôle	Nom	Email	Téléphone
RSSI TALBAGO		rssi@talbago.fr	
DPO		dpo@talbago.fr	
CERT-FR / ANSSI	**CERT-FR**	**cert-fr@ssi.gouv.fr**	

Annexe D — Glossaire

Acronyme	Définition
BYOK	Bring Your Own Key — gestion des clés de chiffrement par TALBAGO
CSPM	Cloud Security Posture Management — outil de contrôle de la conformité des configurations Cloud
DPA	Data Processing Agreement — accord de traitement des données (sous-traitance RGPD)
HSM	Hardware Security Module — dispositif matériel de gestion securisee des cles cryptographiques
IAM	Identity and Access Management — gestion des identités et des droits d'accès
IaC	Infrastructure as Code — gestion de l'infrastructure via des scripts versions
KMS	Key Management Service — service de gestion des clés de chiffrement
MFA	Multi-Factor Authentication — authentification a plusieurs facteurs
PAM	Privileged Access Management — gestion des accès à privilèges élevés
PRA	Plan de Reprise d'Activité — procédure de restauration après incident
RPO	Recovery Point Objective — perte de données maximale admissible
RTO	Recovery Time Objective — durée maximale de restauration admissible
RSSI	Responsable de la Sécurité des Systèmes d'Information
SAST	Static Application Security Testing — analyse statique de sécurité du code
SCA	Software Composition Analysis — analyse des composants logiciels tiers
SIEM	Security Information and Event Management — centralisation des évènements de sécurité
VPC	Virtual Private Cloud — réseau privé virtuel dans le Cloud
WAF	Web Application Firewall — pare-feu applicatif web
ZTNA	Zero Trust Network Access — accès réseau sans confiance implicite

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite